

NACLs

Stateless, Ordered Allow/Deny Filtering at the Subnet Boundary

Interview Preparation Guide

Problem & motivation - statelessness & ordering - ephemeral ports - packet flow - failure modes
- scaling - security - observability & automation - cost - troubleshooting - real-world patterns

Table of Contents

1. The Problem It Solves	3
2. How It Works Internally	3
3. Traffic Flow, Packet Flow & Routing Decisions	4
4. Advantages & Disadvantages	5
5. Common Failure Modes	5
6. Scaling Considerations	5
7. Security Implications	5
8. Observability, Reliability & Automation	6
9. Cost Considerations	6
10. Troubleshooting Approach	6
11. Real-World Examples & Patterns	7
12. Senior-Level Trade-offs & Talking Points	7
13. Quick Glossary	7

Executive Summary

A Network Access Control List (NACL) is a stateless, ordered firewall applied at the boundary of a subnet. Unlike security groups, NACLs evaluate numbered rules in order (first match wins), support both ALLOW and DENY, and - critically - are stateless, meaning you must allow the return traffic explicitly, including the ephemeral port range used for responses. NACLs act as a coarse, subnet-wide backstop beneath security groups and are the source of the single most common VPC connectivity bug. This guide covers internals, packet flow, failure modes, scaling, security, observability, automation, cost, and troubleshooting.

1. The Problem It Solves

Sometimes you need a coarse, subnet-wide guardrail that can explicitly DENY traffic (e.g., block a malicious CIDR) independent of the many security groups inside that subnet. NACLs provide that subnet-level, deny-capable layer of defense in depth.

Core needs NACLs address

- **Explicit deny:** Block specific IPs/ports that allow-only SGs cannot.
- **Subnet-wide backstop:** One coarse control covering every ENI in a subnet.
- **Defense in depth:** A second, independent layer beneath security groups.
- **Blast-radius limiting:** Contain compromised subnets at their boundary.

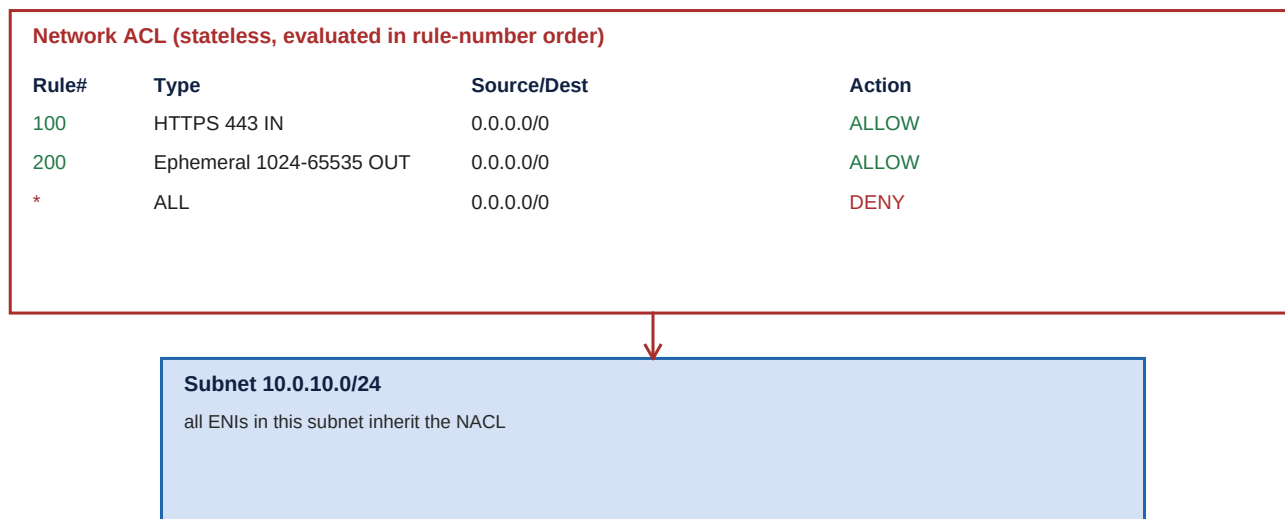
2. How It Works Internally

Each subnet is associated with exactly one NACL (the default NACL allows all). A NACL has separate, numbered inbound and outbound rule lists. For each packet crossing the subnet boundary, rules are evaluated from lowest number upward; the first match (ALLOW or DENY) is applied and evaluation stops. A final, un-editable '*' rule denies anything unmatched.

- Stateless: the response to an allowed inbound request is NOT automatically allowed outbound - you must add an outbound rule (and vice versa).
- Responses use ephemeral source ports (typically 1024-65535), so return rules must allow that range.
- Lower rule numbers take precedence; leave gaps (100, 200, ...) for inserts.
- NACLs filter at the subnet edge; intra-subnet traffic between ENIs is not evaluated by the NACL.

Reference Diagram - Stateless NACL at the subnet boundary

A Network ACL is a stateless, ordered, allow/deny firewall evaluated at the SUBNET boundary. Because it is stateless, you must explicitly allow BOTH the request AND the return traffic - including ephemeral ports for responses.



Rules are processed lowest-number first; the first match wins, then evaluation stops. The final '*' rule denies anything unmatched. Forgetting the ephemeral-port ALLOW (rule 200) is the classic cause of one-way connectivity.

3. Traffic Flow, Packet Flow & Routing Decisions

Both directions must be allowed

- Inbound request to a subnet: inbound NACL rules checked in order; first match decides.
- The server's reply LEAVING the subnet is checked against OUTBOUND rules - must allow the client's ephemeral port range.
- For outbound-initiated flows, it is the reverse: outbound allows the request, inbound must allow the ephemeral return.
- NACLs are orthogonal to routing; they filter, they do not forward.

The ephemeral-port trap

Allowing inbound 443 but forgetting an OUTBOUND allow for ports 1024-65535 means requests arrive but responses are dropped - classic one-way connectivity. Always pair request rules with ephemeral return rules.

4. Advantages & Disadvantages

Advantages

- Supports explicit DENY (blocklists) that SGs cannot.
- Subnet-wide coverage as a single coarse control.
- Independent second layer for defense in depth.
- Ordered rules give deterministic precedence.

Disadvantages / costs

- Stateless - easy to break with missing ephemeral-port return rules.
- Coarse (subnet-level) - cannot express per-instance identity.
- Rule-count limits per NACL.
- Ordering mistakes silently change behavior.

5. Common Failure Modes

Failure	Symptom	Typical root cause
Missing ephemeral allow	One-way / hangs	Return ports 1024-65535 not allowed on the opposite direction.
Rule-order mistake	Wrong allow/deny applied	A broad rule with a lower number shadows a specific one.
Over-broad DENY	Legit traffic blocked	DENY rule too wide or mis-numbered.
Wrong NACL assoc	Unexpected block/allow	Subnet associated with the wrong NACL.
Forgot default deny	False sense of security	Assuming SG covers it; NACL '*' denies unmatched.
Rule-limit hit	Cannot add rule	Too many entries; needs consolidation.

6. Scaling Considerations

- **Keep them coarse:** Use NACLs for broad guardrails; do fine-grained work in SGs.
- **Number with gaps:** Space rule numbers (100, 200) to insert later without renumbering.
- **Consolidate:** Summarize CIDRs to stay within per-NACL rule limits.
- **Standardize:** Reuse a small set of vetted NACL templates across subnets.

7. Security Implications

- Use NACLs to block known-bad CIDRs at the subnet edge.
- Pair with security groups - NACL is the backstop, SG is the primary control.
- Beware: a too-strict NACL can break health checks and responses subtly.
- Document ephemeral-port rules so they are not 'cleaned up' by mistake.

8. Observability, Reliability & Automation

Observability

- Flow Logs show REJECT - but note both SG and NACL can cause it; correlate.
- Reachability Analyzer flags NACL rules that block a path.

Reliability

- Always include ephemeral-port return rules to avoid intermittent breakage.
- Change NACLs cautiously - they affect every ENI in the subnet at once.

Automation

- Template NACLs in IaC with explicit ephemeral-port rules.
- Lint rules for ordering hazards and missing return ranges.

9. Cost Considerations

Cost driver	Why it adds up	Mitigation
NACLs	Free - no charge for NACLs or rules.	N/A; cost is operational risk from misconfiguration.
Outage risk	Stateless mistakes cause incidents.	Standard templates + automated linting of ephemeral rules.
Debug time	Hard-to-spot one-way failures.	Flow Logs correlation + Reachability Analyzer.

10. Troubleshooting Approach

When connectivity is one-way or intermittent, suspect the NACL:

- 1. Which NACL is on each subnet in the path?
- 2. Inbound rules: is the request port allowed?
- 3. Outbound rules: is the ephemeral return range (1024-65535) allowed?
- 4. Check rule ORDER - is a lower-numbered rule shadowing the intended one?
- 5. Correlate Flow Log REJECTs; remember SG vs NACL both can reject.

Mnemonic

'Order -> Request -> Ephemeral return.' If SGs look fine but it's one-way, it's almost always a missing ephemeral NACL rule.

11. Real-World Examples & Patterns

- **Blocklist:** DENY a malicious CIDR at the subnet edge while SGs stay allow-only.
- **Tier isolation:** Coarse NACLs reinforcing that data subnets only talk to app subnets.
- **Default-allow + targeted deny:** Permissive NACL with a few high-priority DENY rules.
- **Compliance backstop:** NACLs as an auditable, subnet-wide control layer.

12. Senior-Level Trade-offs & Talking Points

- NACLs (stateless, deny-capable, coarse) vs SGs (stateful, allow-only, fine) - layer them, don't choose one.
- Strict NACLs (more control) vs operational fragility (ephemeral-port breakage).
- Subnet-wide blast control vs inability to express per-instance identity.
- When to reach for AWS Network Firewall instead of complex NACLs.

Whiteboard checklist

(1) Draw subnet boundary with NACL. (2) Show ordered numbered rules. (3) Add request + ephemeral return on opposite directions. (4) Note first-match-wins and '*' deny. (5) Contrast statefulness with SGs.

13. Quick Glossary

Term	Meaning
NACL	Network ACL - stateless subnet-level allow/deny firewall.
Stateless	Return traffic must be allowed explicitly.
Ephemeral ports	High source ports (1024-65535) used by responses.
Rule number	Determines evaluation order; lowest first, first match wins.
Default NACL	Allows all traffic until you customize it.
'*' rule	Final, un-editable DENY for unmatched traffic.
First-match-wins	Evaluation stops at the first matching rule.